

Contents

1	DD12: 運営者用ログ・テスト (運営者システム)	1
1.1	0. 文書情報	1
1.2	1. 対象範囲	1
1.3	2. 収録ロジック・対応章	1
1.4	3. 詳細設計本文	2
1.4.1	3.1 構造化ログ JSON Schema(★TH-11)	2
1.4.2	3.2 機密項目マスキング	2
1.4.3	3.3 エラー ID 体系	2
1.4.4	3.4 RFC 7807 problem+json 形式	3
1.4.5	3.5 テスト種別 × 責務(基本設計 §14.1 準拠)	3
1.4.6	3.6 SCR × FR × AC × テストレベル早見表	4
1.4.7	3.7 受入条件マッピング(本書側主管)	4
1.4.8	3.8 品質回帰データセット	4
1.4.9	3.9 負荷試験(顧管側、メイン §17.5 と対称形)	5
1.4.10	3.10 トレース ID 採番	5
1.4.11	3.11 ログ集約 + 検索	5
1.4.12	3.11.1 SCR-096 異常検知バッジ → フィルタ自動投入(画面側ロジック)	5
1.4.13	3.11.2 SCR-HOME 緊急アラート 0 件時の「異常なし」バナー(画面側ロジック)	6
1.4.14	3.12 テストインフラ	6
1.4.15	3.13 リリース判定チェックリスト(MVP)	6
1.5	4. 関連設計	6
1.6	5. テスト観点	7
1.6.1	5.1 構造化ログのスキーマ整合性	7
1.6.2	5.2 テストインフラ自体の検証	7
1.6.3	5.3 受入条件カバレッジ計算	7
1.7	6. 未確定事項・確認事項	7

1 DD12: 運営者用ログ・テスト (運営者システム)

1.1 0. 文書情報

項目	内容
文書名	DD12: 運営者用ログ・テスト (運営者システム)
詳細設計 ID	DD12
対象システム	FAQ AI ウィジェット SaaS / 運営者システム
関連機能 ID	TH-11, NFR-103, NFR-105, NFR-106, AC-034, AC-036, AC-037, AC-038, AC-040, AC-041, AC-042, AC-044, AC-046
作成日	2026-05-17
版数	v1.0
ステータス	承認済

1.2 1. 対象範囲

種別	ID	名称
機能	TH-11	エラーログ詳細 (構造化ログ)
テスト	ユニット / 結合 / E2E / Webhook 統合 / 負荷 / ペネトレ	全テストレベル
受入条件	AC-034~046	本書側主管 AC + メイン共同 AC

1.3 2. 収録ロジック・対応章

元章	元タイトル	概要
§16	エラーログ・構造化ログ(★TH-11)	エラー ID 体系 + 構造化ログスキーマ(個別設計書参照)
§17 全文	テスト戦略・受入条件マッピング	テスト種別 × 責務 + AC マッピング + 負荷シナリオ + 品質回帰データセット

元章	元タイトル	概要
付録 K	構造化ログ JSON Schema	実装ファイルとの一致要求

1.4 3. 詳細設計本文

1.4.1 3.1 構造化ログ JSON Schema(★TH-11)

すべての Worker は標準出力に JSON 1 行形式で構造化ログを出力する。Logpush / Logflare 等の集約基盤に送られ、Trace ID で横串集計可能。

```
{
  "level": "debug | info | warn | error | critical",
  "timestamp": "2026-05-12T10:00:00Z",
  "worker": "AdminConsoleWorker",
  "request_id": "<cf-ray>",
  "trace_id": "01J...",
  "operator_id": "01J... | null",
  "contract_owner_user_id": "01J... | null",
  "action": "<action_code> | null",
  "endpoint": "/admin/api/v1/...",
  "method": "GET | POST | PUT | DELETE",
  "status_code": 200,
  "duration_ms": 123,
  "error_code": "E-OP-... | null",
  "error_message": "...",
  "stack_trace": "..."
}
```

必須フィールド: level、timestamp、worker、request_id。任意フィールド: trace_id、operator_id、contract_owner_user_id、action、endpoint、method、status_code、duration_ms、error_code、error_message、stack_trace。

実装ファイル admin/src/shared/logger.ts の型定義と一致させること。

1.4.2 3.2 機密項目マスキング

ログ出力前に必ず次のフィールドをマスクする:

フィールド	マスキング
Authorization ヘッダ	完全削除
X-CSRF-Token	最初の 4 文字 + ***
パスワード / MFA コード / リカバリーコード	完全削除
メール本文 PII / 電話番号 / クレカ	DD10 と同方式でマスク
Stripe customer.id	末尾 4 文字 + *** (法令対応で完全削除は避ける)
IP アドレス	/24(IPv4) / /48(IPv6) 単位で切り捨て

1.4.3 3.3 エラー ID 体系

エラー ID 体系の正本は [基本設計 / エラー設計](#)。E-OP-* 87 件、エラー分類 13 種、異常系共通方針、critical レベルエラーは当該ドキュメントを参照。

主な接頭辞:

接頭辞	範囲	DD 参照
E-OP-AUTH-*	認証 / 認可	DD01
E-OP-4EYES-*	4-eyes	DD02
E-OP-AUDIT-*	監査ログ	DD03
E-OP-WEBHOOK-*	Webhook	DD04
E-OP-RESTORE-*	削除データ復元	DD05
E-OP-ANN-*	お知らせ	DD06

接頭辞	範囲	DD 参照
E-OP-PII-*	PII 報告	DD10
E-OP-STATE-*	状態遷移共通	DD11

1.4.4 3.4 RFC 7807 problem+json 形式

エラーレスポンスは RFC 7807 に準拠:

```
{
  "type": "https://admin.open-faq.example.com/errors/E-OP-AUTH-005",
  "title": "Re-authentication required",
  "status": 403,
  "code": "E-OP-AUTH-005",
  "detail": "Critical operation requires re-authentication within 5 minutes",
  "trace_id": "01J...",
  "instance": "/admin/api/v1/owners/01J.../suspend"
}
```

type フィールドは **code** フィールドと同一のエラー ID を URL 末尾に持ち、運営者がドキュメントへ到達可能にする。

1.4.5 3.5 テスト種別 × 責務 (基本設計 §14.1 準拠)

種別	範囲	ツール	実施タイミング	責務
ユニット	Workers ハンドラ・ドメインロジック・SLA 計測・ハッシュチェーン計算	Vitest	コミット毎	本書
結合	D1/R2/KV を含む、運営者認証・4-eyes 承認・Webhook 受信	Miniflare + Vitest	PR 毎	本書
E2E(運営画面)	SCR-090~099 主要フロー、4-eyes 承認、削除データ復元、お知らせ配信	Playwright	nightly + リリース前	本書
Webhook 統合	Stripe 署名検証、event_id 幕等、ペイロード差分検出、DLQ 自動 BO、手動リプレイ	カスタム + Stripe Test Mode	リリース前 + 月次	本書
AI 品質回帰	FAQ × 想定質問ペア (MVP 50)	カスタムバッチ	モデル更新時 + プロンプト変更時	データセット = 本書、実行 = メイン CI
プロンプト注入回帰	20 ケース以上	カスタム	モデル更新時 + 四半期	テストセット = 本書、実行 = メイン CI
ペネトレーション	全エンドポイント (運営者プレーン重点)	外部委託	年 1 回 + 重大機能変更時	共同 (本書側で実施記録 5 年保持)
オーナー境界によるデータ分離	クロス契約アクセス試行 (自動 50 + 手動 5)	カスタム	月次自動 + 年次手動	メイン主管 + 本書側で運営者横断クエリ境界
負荷試験	監査ログ検索 (100 万件以下)/ エクスポート (10 万行/60s)/ 4-eyes 承認 API	k6	月次 + 主要リリース前	本書
4-eyes E2E	申請 → 承認 → 実行 → 失敗ロールバック	Playwright	nightly	本書

カバレッジ目標 (MVP リリース判定で達成必須):

種別	目標値	補足
ユニット state-ments	☑ 80%	SLA 計測 / ハッシュチェーン計算は ☑ 90%
ユニット branches	☑ 75%	状態遷移ガード系は ☑ 90%
結合 (Miniflare)	API エンドポイント網羅率 100%	認可境界・状態遷移 1 件以上
E2E(Playwright)	SCR-090~099 各画面で主要フロー 1 件以上 + 4-eyes 完全フロー	—
AC マッピング	§ 3.8 受入条件すべてに対応するテスト ID	AC 識別子をテスト記述に埋め込み

負荷試験シナリオ詳細 (本書主管):

シナリオ	構成	目的
(A1) 監査ログ検索負荷	audit_logs 100 万件、SCR-096 検索 50 RPS	p95 ☒ 1000ms 検証
(A2) 監査ログエクスポート	10 万行/ファイル、5 並列実行	☒ 60s + メモリ上限遵守
(A3) 4-eyes 承認バースト	同時申請 50 件 / 承認 50 件	楽観ロック・状態遷移整合性
(A4) Stripe Webhook 受信	100 event/分 + 10% で差分検出	冪等性 + DLQ 挙動

合格基準: 全シナリオで基本設計 § 13.1 目標値 + http_req_failed < 1%。

ペネトレーション実施記録テンプレート (5 年保持):

- ・ 保管場所: docs/security/pentest/YYYY-MM-DD.md (TBD: 初回実施時に確定)
- ・ 記載項目: scope / 実施者 / 日付 / findings (Critical/High/Medium/Low) / retest 結果 / 残課題チケット ID
- ・ 整合: GitHub Issue に findings を同期 (Critical/High はセキュリティ SLA に対応)

1.4.6 3.6 SCR × FR × AC × テストレベル早見表

SCR	主 FR	AC	ユニット	結合	E2E
SCR-090	FR-200, FR-223	-	検索条件バリデーション	API 経由表示	一覧表示 + 詳細遷移
SCR-091	FR-201~211	-	(a)~(g) 各ステップ	トランザクション + ロールバック	復元フロー全体 + 423 ケース
SCR-092	FR-055, FR-061~066	AC-034	階層解決	KV PUT + メイン同期	4-eyes ハードゲート + 段階ロールアウト
SCR-093	FR-121, FR-128	AC-040, AC-044	バリデーション	KV PUT	上書き + IF #5 同期
SCR-094	FR-149, FR-188-189	-	サニタイズ	1 分 cron 配信	予約 + 取消 + テスト送信 + 訂正告知
SCR-096	FR-229, FR-230, FR-232	AC-038	ハッシュチェーン計算	カーソル検索	エクスポート + HMAC 検証
SCR-097	FR-302, NFR-808	AC-041	状態遷移	DLQ 自動 BO + 手動リプレイ	30 日ウィンドウ
SCR-098	FR-060, FR-064	AC-036	ルール更新	KV 即時反映	3 営業日タイマー
SCR-099	FR-302 異常系	AC-041	差分検出アルゴリズム	同 event_id 再送	dismiss / reprocess

1.4.7 3.7 受入条件マッピング (本書側主管)

AC	主管	検証手段
AC-036 (PII 3 層 + 報告フロー)	本書	単体 + 報告 E2E + 都度運用
AC-037 (運営者 MFA + 再認証)	本書	認証テスト
AC-038 (運営者操作監査 + 通知)	本書	E2E + 月次監査
AC-041 (Webhook 冪等性 + 差分検出)	本書	統合テスト (差分検出ケース含) + リプレイ運用
AC-042 (月次請求 cron 冪等)	本書	統合テスト
AC-046 (p95 4 週間達成)	メイン主管 / 本書観測	Analytics Engine ダッシュボード

1.4.8 3.8 品質回帰データセット

データセット	件数 (MVP)	管理	実行
AI 品質回帰 (質問 →FAQ→ 回答)	50	本書 SCR-096 経由	メイン CI
プロンプト注入	20+(役割再定義 / タグ脱出 / コード注入 / 言語切替 / 指示上書き / ロール変更 / SP 開示 / FAQ 外事実 / 機密抽出)	本書	メイン CI
PII 第1層	陽性 100 + 陰性 100 / 各国内パターン	本書	本書 CI
HTML サニタイズ攻撃	50 ペイロード	本書	本書 CI

1.4.9 3.9 負荷試験 (顧客側、メイン §17.5 と対称形)

メイン §17.5 で定義した 5 シナリオ (S1～S5) に加え、本書側 (運営者画面) 固有のシナリオを以下に定義する。

シナリオ	構成	目的	合格基準
(A1) 監査ログ大量検索	200 契約 × 5 年分監査ログ (約 550 万行) を GET /audit-logs で (action, occurred_at) 範囲検索 100 並列	SCR-096 検索性能 / インデックス選択性	p95 ☒ 1000ms
(A2) 監査ログ大量エクスポート	10 万行エクスポートを 5 並列で同時起動	R2 chunk PUT のスループット、メモリ上限 128MB の遵守	全ジョブ完了 ☒ 90s、メモリ上限 ヒット率 0%
(A3) Webhook 集中受信	Stripe Webhook 1000 件/分 × 5 分間	署名検証 + 冪等性ストア (KV) のスループット	p95 ☒ 500ms、web-hook_events.state 整合性 100%
(A4) 4-eyes 同時申請	100 申請を 10 秒間に集中投入、別運営者から 100 並列承認	operator_approvals テーブルの楽観ロック、同時実行制御	レース条件で重複承認 = 0 件、申請 → 承認 → 実行が単調進行
(A5) DLQ 大量リプレイ	1000 件の dlq_manual_replay を同時起動	サーキットブレーカ・指数 BO の挙動	サーキットブレーカ open 率が想定通り、5xx → 自動 BO で全件最終完了

実行: k6 + Miniflare 組合せ。月次 + 主要リリース前。初回実施日 + k6 シナリオファイル所在は SRE が運用設計に記載する (TBD)。

1.4.10 3.10 トレース ID 採番

採番場所	形式
エッジ (Cloudflare)	<cf-ray>(自動付与、request_id フィールド)
Worker 内	ULID 26 文字を新規発行、trace_id フィールド
クライアント送出	X-Trace-Id ヘッダ (任意、Worker は受け取った値を継承)
連携 IF #1～#12	mTLS + JWT に trace_id クレーム含有

trace_id は構造化ログ・audit_logs.trace_id 列・エラーレスポンス trace_id フィールドのすべてで一致する。

1.4.11 3.11 ログ集約 + 検索

項目	仕様
集約基盤	Cloudflare Logpush → 外部ストア (MVP では R2 + 必要時に DuckDB クエリ)
保持	エラーログ 90 日、トレースログ 30 日 (R2 lifecycle rule)
検索	運営者は SCR-096 経由でエラーログをフィルタ可能 (action_code = error.log で監査記録)
アラート	level=critical で運営者 critical alert (オーナー + 全プロジェクト管理者 (project_users.role='admin' を 1 件でも保持するユーザー)、強制送信)

1.4.12 3.11.1 SCR-096 異常検知バッジ → フィルタ自動投入 (画面側ロジック)

SCR-096 運営者活動ダッシュボードの「ハッシュチェーン検証バッジ」「運営者操作頻度異常検知バッジ」は、基本設計 01_画面設計.md §5.9 で「異常時はクリックで一覧フィルタに条件を自動投入」と定義する。本節はその画面側ロジックを補足する。

バッジ	平常時表示	異常時表示	クリック時のフィルタ自動投入
ハッシュチェーン検証バッジ(MSG-SCR-096-BADGE-001/002)	☒ 検証済(過去24h)、クリック不可	☒ 確認が必要(該当区間[from, to]含む)、クリック活性	occurred_at フィルタに [from, to] を自動投入し、一覧を再検索。クイックフィルタチップ「異常検知あり」を選択状態にする
運営者操作頻度異常検知バッジ(MSG-SCR-096-BADGE-003/004)	☒ 操作頻度: 正常、クリック不可	☒ 操作頻度異常 actor_id={op_xxx}、クリック活性	actor_id フィルタに該当 op_xxx を自動投入し、occurred_at に検知ウィンドウ(直近1時間等)を自動投入。一覧を再検索

- ・異常検知の出元は AuditChainVerifierWorker(運営者 DD03_ 監査ハッシュチェーン.md) および OperatorActivityAnomalyDetector(検知ロジックはアラート閾値: 直近1時間で200操作以上 / actor)。検知結果は GET /admin/v1/home および GET /admin/v1/audit-logs/anomalies レスポンスに含めて画面に渡す。
- ・画面側は、フィルタ自動投入後の URL にクエリパラメータを付与 (?actor_id=op_xxx&from=...&to=...) して、戻る操作 / シェアにも対応する。
- ・☒ 全クリア(現在の絞り込み解除) チップ(MSG-SCR-096-CHIP-CLEAR-001) はクイックフィルタチップ群に常時併置し、クリックで全フィルタを初期値に戻す。

1.4.13 3.11.2 SCR-HOME 緊急アラート 0 件時の「異常なし」バナー (画面側ロジック)

基本設計 01_画面設計.md §5.3 で定義する SCR-HOME 緊急アラート帯は、件数が1件以上ある場合は赤系アラートを表示するが、**全アラートが 0 件のときは緑系の「☒ 異常なし」バナー (MSG-SCR-HOME-OK-001) を表示する**。これは「アラート表示が壊れているのか平常なのか」をユーザーが判別できるようにするための明示的な肯定表示。

- ・表示判定: GET /admin/v1/home のレスポンスで以下がすべて 0 のとき。
 - approval.expiring_within_24h_count
 - webhook.dlq_stalled_24h_count
 - pii.sla_exceeded_count
 - audit.hash_chain_breach_count
- ・バナー文言: 「☒ 緊急対応が必要な事案はありません(ハッシュチェーン: 検証済 / 操作頻度: 正常)」
- ・ハッシュチェーン / 操作頻度の状態は同じ API レスポンスに含めて返す(運営者 API 設計参照)。

1.4.14 3.12 テストインフラ

項目	仕様
ユニット	Vitest(vitest.config.ts、CI: GitHub Actions)
結合	Miniflare(vitest -pool=workers)
E2E	Playwright(playwright.config.ts、CI: nightly + リリース前)
Webhook 統合	Stripe Test Mode + カスタムフィクスチャ
負荷	k6 + Miniflare(tests/load/*.js)
カバレッジレポート	Vitest coverage + CodeCov 連携

1.4.15 3.13 リリース判定チェックリスト (MVP)

- ☐ ユニット statements ☒ 80%、branches ☒ 75%
- ☐ 結合 API エンドポイント網羅率 100%
- ☐ E2E: SCR-090~099 主要フロー + 4-eyes 完全フロー (5 シナリオ)
- ☐ Webhook 統合: 署名検証 / 幂等 / 差分 / DLQ / リプレイ
- ☐ AI 品質回帰: 50 件 + プロンプト注入 20 件
- ☐ PII 第1層: 陽性 100 + 陰性 100
- ☐ HTML サニタイズ: 50 ペイロード
- ☐ 負荷試験: A1~A5 全合格
- ☐ ペネトレ: Critical/High 0 件 (年1回 + 重大機能変更時)
- ☐ AC-036 / AC-037 / AC-038 / AC-041 / AC-042 すべて緑

1.5 4. 関連設計

種別	参照先
要件	../01_要件定義/index.md
基本設計	../02_基本設計/index.md
エラー設計(正本)	../02_基本設計/05_エラー設計.md
トレーサビリティマトリクス	../02_基本設計/07_トレーサビリティマトリクス.md
関連 DD	DD01～DD11 全 11 ファイル
運用設計	../04_運用設計/index.md
将来対応	../05_future/index.md

1.6 5. テスト観点

(本書自体がテスト戦略を定義する文書のため、テスト観点はメタとして以下を含む。)

1.6.1 5.1 構造化ログのスキーマ整合性

- ・ `admin/src/shared/logger.ts` の TypeScript 型定義と JSON Schema の一致を CI で検証
- ・ 機密項目マスキング関数のユニットテスト(各種 PII / 認証情報)
- ・ ログ集約後の検索 SLO(p95 ☒ 5s 以内に取得可能)

1.6.2 5.2 テストインフラ自体の検証

- ・ Miniflare 環境での D1 / KV / R2 のローカル動作確認
- ・ k6 シナリオの本番モック性(統計分布の妥当性)
- ・ Playwright の並列実行とレース条件耐性

1.6.3 5.3 受入条件カバレッジ計算

- ・ AC ID をテスト記述に埋め込み、`03_script/check-ac-coverage.sh`(TODO: 整備中) で網羅率を計算
- ・ カバレッジ < 95% で CI fail

1.7 6. 未確定事項・確認事項

確認事項 ID	確認内容	優先度	ステータス
-	v1.0 リリース時点で全項目確定済み	低	確認済
TBD-DD12-001	k6 シナリオファイルの初回実施日(SRE 主管、運用設計に記載予定)	中	未確定
TBD-DD12-002	ペネトレーション実施記録の正式パス(docs/security/pentest/YYYY-MM-DD.md)の運用開始	中	未確定